

Project 3: Phishing Awareness Analysis

Phishing Triage Toolkit — Sample Analysis, Checklist & Decision Tree

Prepared by: Yahaya Abdullahi | Student ID: AIU25102097 | Batch 2026

1. Objective

This report analyzes three simulated phishing messages representing common attack patterns (credential harvesting, business email compromise, and callback phishing). For each sample, suspicious links/keywords are identified, red flags are listed, and a plain-language explanation is given for why the message is unsafe. The report concludes with a non-expert triage checklist and a decision tree that classifies any incoming message as Safe, Suspicious, or Malicious with a defined next action.

2. Sample Message Analysis

Sample 1 — Credential Harvesting ("IT Password Reset")

From: IT Security <support@login-updates.com>

To: employee@company.com

Subject: Mandatory: Your Password Expires in 24 Hrs

Dear User,

Our records show your company password will expire in 24 hours. To avoid being locked out of your account, you must verify your credentials immediately using the secure link below.

Verify Now: <https://www.company.tech.login-update.com/reset>

Failure to act within 24 hours will result in permanent account suspension.

Thank you,

IT Security Team

Red Flag	Evidence in Message	Why It Matters
Sender-domain mismatch	Display name "IT Security" but real domain is login-updates.com, not the company's domain.	Attackers spoof a trusted display name while routing through an external domain.
Nested/lookalike domain	company.tech.login-update.com — the true root domain (login-update.com) is buried after a fake subdomain that mimics the real company name.	Reading right-to-left reveals the actual destination is not the company.

Red Flag	Evidence in Message	Why It Matters
Urgency pressure	"expires in 24 hours," "immediately," "permanent account suspension."	Time pressure is designed to trigger a fight-or-flight response and bypass careful checking.
Generic greeting	"Dear User" instead of the employee's actual name.	Legitimate internal IT systems typically address staff by name.
Credential request via link	Link leads to a login/verification page.	No legitimate IT team asks users to "verify" credentials through an emailed link.

Verdict: MALICIOUS

Domain spoofing combined with a credential-harvesting link and manufactured urgency. This message should be reported, not clicked, and the domain should be blocked.

Sample 2 — Business Email Compromise ("CEO Wire Transfer")

From: CEO Name <ceo.urgent@executive-update.com>

To: finance@company.com

Subject: IMMEDIATE ACTION REQUIRED: Transfer Authorization

URGENT: Process the attached wire transfer instruction immediately.

This is critical and must remain STRICTLY CONFIDENTIAL. Do not discuss with anyone. Bypass standard procedure — I am in back-to-back meetings and cannot be reached by phone.

Thank you.

Red Flag	Evidence in Message	Why It Matters
Authority impersonation	Sender claims to be the CEO, a role chosen specifically to discourage questioning.	Attackers exploit deference to authority to push urgent, unverified action.
Domain spoofing	executive-update.com is not the company's real domain, despite the trusted display name.	The From address, not the display name, determines the true sender.
Secrecy + bypass request	"STRICTLY CONFIDENTIAL," "do not discuss," "bypass standard procedure."	Legitimate finance processes never ask staff to skip verification or hide a transaction.
Manufactured unreachability	"Cannot be reached by phone."	This removes the easiest way to verify the request, isolating the

Red Flag	Evidence in Message	Why It Matters
		target.
High-value financial ask	Wire transfer authorization with no purchase order or prior discussion.	Unplanned, high-value financial requests always warrant independent verification.

Verdict: MALICIOUS

Classic Business Email Compromise (BEC) pattern: authority + secrecy + urgency + a request to bypass controls. Finance should verify through a known internal number before taking any action, and report the email.

Sample 3 — Callback Phishing / TOAD ("Microsoft Subscription Renewal")

From: Microsoft Billing <no-reply@microso0ft-billing.com>

To: employee@company.com

Subject: Payment Overdue — Subscription Will Be Cancelled

Official Notice — Microsoft Subscription Renewal

Order Number: 900125033233

Amount Charged: \$190.60

If you did not authorize this charge, call 1-800-XXX-XXXX IMMEDIATELY to cancel and receive a refund. No link is provided for your security.

Red Flag	Evidence in Message	Why It Matters
Homoglyph domain	microso0ft-billing.com uses a zero in place of the letter "o."	A visually near-identical domain is easy to miss at a glance, especially on mobile.
Fear/greed trigger	Unexpected charge notice designed to provoke concern about being billed and a desire to get a refund.	Emotional reaction short-circuits careful evaluation of the message's legitimacy.
No link — phone-only	The message intentionally omits a clickable link, providing only a phone number.	This is a Callback Phishing (TOAD) pattern: the "safety" of no-link is used to build false trust, then the scam continues live over the phone.
Unverified contact number	The 1-800 number is supplied by the attacker, not sourced from Microsoft's official site.	Calling it connects the victim directly to the attacker, who then requests payment details or remote access.

Verdict: MALICIOUS

No malicious link is present, but the homoglyph domain and unverified callback number indicate a Callback Phishing (TOAD) attempt. Do not call the number in the email — verify any charge directly through the official Microsoft account portal.

3. Non-Expert Triage Checklist

A quick-reference checklist any employee — regardless of technical background — can apply to an incoming message before acting on it.

#	Check	What To Look For	Non-Expert Tip
1	Sender address vs. display name	Tap/hover the sender name to reveal the real email address. Does the domain match the company it claims to be from?	If the name says "IT Support" but the address is a Gmail or odd domain — stop.
2	Domain spelling	Look character-by-character at the domain (e.g., amaz0n.com, paypa1.com, company-secure-login.com).	Read the URL right to left; the real domain is closest to ".com".
3	Urgency / pressure language	Words like "immediate," "24 hours," "account locked," "final notice."	Real IT/HR rarely demands action in minutes.
4	Requests for secrets	Passwords, MFA codes, OTPs, bank details, gift cards.	No legitimate department asks for these by email or text.
5	Links before clicking	Hover (desktop) or long-press (mobile) to preview the actual URL.	If the visible text and real link don't match, don't click.
6	Attachments	Unexpected files, especially .iso, .js, .scr, .html, or password-protected zips.	When in doubt, don't open — verify with the sender first.
7	Tone and consistency	Spelling errors, generic greetings ("Dear User"), mismatched logos/formatting.	Compare against a previous legitimate email from the same sender.
8	Secondary channel verification	Can the request be confirmed by phone, in person, or via a known internal system?	Never use contact details supplied in the suspicious message itself.

4. Decision Tree: Safe / Suspicious / Malicious

Every triage event must end in one of the three definitive actions below.

Classification	Trigger Conditions	Action	Owner
SAFE	Sender domain verified and matches	CLOSE	End user

Classification	Trigger Conditions	Action	Owner
	known contact; no urgency/secretcy language; no credential or payment request; links resolve to legitimate, expected domains.		
SUSPICIOUS	One or two isolated anomalies (e.g., unusual tone, minor formatting inconsistency, unexpected but plausible attachment) with no direct request for credentials or money.	WARN USER — flag, do not act, verify via known channel	End user + Team Lead
MALICIOUS	Any combination of: domain spoofing/lookalike URL, credential or payment request, urgency + authority pressure, dangerous attachment, mismatched sender/display name, unsolicited QR code, or MFA push flooding.	BLOCK & ESCALATE — report via internal channel, do not delete, block domain	Security/IT team

Golden Rule: PAUSE (recognize the trigger — urgency, fear, authority, curiosity) → VERIFY (confirm through a separate, known channel — never contact details from the message itself) → REPORT (use the internal reporting tool; do not simply delete, so the security team can purge the threat organization-wide).

5. Conclusion

Across all three samples, the unsafe messages share a common structure: a spoofed or lookalike sender identity, a cognitive trigger (urgency, authority, fear, or curiosity) designed to bypass rational verification, and a request that moves the victim toward disclosing credentials, transferring money, or calling an attacker-controlled number. The triage checklist and decision tree above translate these patterns into a repeatable process — Pause, Verify, Report — that closes the gap between technical controls and human judgment, reinforcing the organization's human firewall.